

REVIEW RENDER ONLY - NOT THE PUBLICATION-LAYOUT MASTER
Use the Markdown file on this branch as the authoritative review text.

AI Trust Graph: A Graph-Driven, Evidence-Based Methodology for AI Assurance

Reasoning about trust, authority, paths, controls, evidence, and accountable decisions
across connected AI systems

Siva Sethumadhavan

Whitepaper v1.0-rc.2 - Publication review candidate
October 2026

Methodology baseline: AI Trust Graph methodology bundle 1.0-rc.4, snapshot 26 September 2026
Manifest blob: 82c401ad27d31ddc0078e58dd99f38ac0b71a7d9

Publication status

This whitepaper is a non-normative narrative introduction to the AI Trust Graph methodology. The governed AI Trust Graph methodology artifacts maintained in the public repository remain the canonical source for definitions, controls, evidence grades, maturity rules, scoring rules, assessment procedures, reporting requirements, ontology, governance and conformance requirements. If explanatory language in this paper appears inconsistent with the canonical methodology, the governed canonical artifacts prevail.

This draft is frozen to AI Trust Graph methodology bundle 1.0-rc.4, snapshot 26 September 2026. The corresponding methodology manifest blob is 82c401ad27d31ddc0078e58dd99f38ac0b71a7d9. That pin is a reproducibility reference, not a validation claim.

At this baseline, AI Trust Graph is a public-release candidate. The methodology author's internal review is complete. The following external release gates remain pending until completed and recorded through governance: independent methodology or architecture review; independent AI-security review; an inter-assessor reproducibility study using the protocol in Artifact #10 Appendix B.4; employer, IP and confidentiality review; and legal approval of the licence and trademark position. Nothing in this paper should be interpreted as a claim that AI Trust Graph has been independently validated, academically peer reviewed, standardized, accredited or certified. It is not presented as empirically proven, universally reproducible, or proven effective in production. It does not guarantee AI safety, security, compliance or the absence of failure. Separately, Artifact #4 Section 6.5 requires sensitivity analysis before public use of weighted or path formulas. Completion of that requirement is not recorded at this frozen baseline. This RC2 may circulate for review, but final public release of the whitepaper should remain blocked until the required sensitivity analysis is completed and recorded through governance.

AI Trust Graph is a methodology, not a product. It is vendor-neutral and tool-independent. ExposureGraph product design, proprietary algorithms, connectors, customer data and commercial workflows are outside the public methodology and outside this whitepaper. The author is also the steward of the AI Trust Graph methodology and may explore separate future implementation or commercial work; this paper makes no claim that such work is required to use the methodology. The licence and trademark position for this whitepaper remains subject to the release gate stated above; no licence is implied by the repository licence scope

unless and until that scope is explicitly extended to this publication.

Abstract

AI systems increasingly operate as connected systems of identities, models, agents, tools, data, providers, workflows and human decision points. In such environments, consequential exposure can emerge from composition rather than from one component in isolation. AI Trust Graph (ATG) is an open, vendor-neutral and product-independent methodology for representing and assessing those connected relationships as a directed, labelled multigraph.

ATG follows a single canonical reasoning chain: Objects -> Relationships -> Conditions -> Paths -> Authority and Influence -> Consequence -> Controls -> Evidence -> Decision. It organizes assessment across six domains and seventy-two canonical controls, while keeping evidence strength, control effectiveness, maturity, path exposure and uncertainty distinct. UNKNOWN is preserved when evidence is absent, insufficient or materially conflicting; it is not converted into zero, pass, fail, effectiveness, Not Applicable or Not Tested.

The methodology does not produce a universal trust score. Its Path Exposure Index (PEI) may be used for triage only on determinate eligible active paths; it does not prove exploitability, probability or loss. Maturity is cumulative, evidence-gated and non-compensating rather than averaged.

This whitepaper is a non-normative narrative synthesis of methodology bundle 1.0-rc.4. It explains the graph model, trust, authority and influence, path states and roles, control breakpoints, evidence discipline, assessment lifecycle, scoring boundaries, reporting, governance and current limitations. Historical reference cases are identified as such; current scoring mechanics are illustrated only with calibration vectors explicitly evaluated under rc.4.

1. The assurance problem

1.1 Connected AI changes the unit of analysis

An AI-enabled service is rarely just a model endpoint. In a production environment, it may depend on identity federation, prompt and policy layers, retrieval systems, vector stores, memory, tool invocation, software pipelines, API gateways, model providers, data platforms and human approval workflows. An agent can also inherit the permissions of the workload or user identity under which it operates. A system that appears low-impact when viewed component by component may therefore become consequential when those components are composed.

This creates an assurance problem. A component inventory can establish what exists. A control checklist can establish whether expected safeguards are claimed or observed at individual points. A policy can define desired behaviour. None of these views, by itself, guarantees that the assessor can answer a different set of questions: What can this component reach? Through which identity? Under what authority? Across which boundary? Under what preconditions? Which control would stop, constrain, detect or contain the path? What evidence supports each step? What remains unresolved?

The AI Trust Graph methodology is designed around those questions. It does not assume that risk exists only inside a model, nor that every graph connection is dangerous. It treats material assurance as a systems problem in which the composition of relationships, permissions and dependencies can matter as much as the security posture of individual components [ATG-1][ATG-2].

1.2 From component posture to composed consequence

Consider an enterprise assistant that can retrieve internal documents. A conventional review may verify that the model is approved, the application is registered, authentication is enabled and the document platform has access controls. Those are useful facts. But the consequential question may be whether the assistant's retrieval path applies user-level authorization correctly for every source. If a retriever executes with a broad service entitlement, then a user who cannot directly open a restricted document may still obtain content through the assistant. The material risk emerges from a sequence: user identity -> assistant -> retriever -> inherited source entitlement -> restricted document.

The weakness is not necessarily located in the model. It may be produced by the interaction between identity, retrieval architecture, data permissions and missing validation evidence. That is exactly the kind of relationship-dependent assurance problem a graph representation is intended to make explicit.

1.3 Complement, not replacement

AI Trust Graph is not positioned as a substitute for established AI risk, security or management frameworks. NIST AI RMF 1.0 provides a voluntary framework for managing AI risk, and NIST's Generative AI Profile extends that work for generative-AI risks [1][2]. ISO/IEC 42001:2023 defines requirements for an AI management system, while ISO/IEC 23894:2023 provides guidance for AI risk management [3][4]. MITRE ATLAS organizes adversary tactics and techniques involving AI systems [5]. OWASP's 2026 agentic-security work addresses risks and runtime control for autonomous agents, including the Top 10 for Agentic Applications and the Agent Control Standard [6][7]. The World Economic Forum's 2026 agent playbook also emphasizes explicit authorization profiles, auditability and accountable delegated action [8].

AI Trust Graph addresses a narrower methodological question: how to represent and assess connected trust, authority and exposure relationships, link them to controls and evidence, preserve uncertainty, and produce bounded assurance conclusions. It is therefore intended to interoperate with, and provide evidence to, broader governance, risk and security processes rather than replace them.

1.4 Related work and differentiation

Graph-based security analysis is not new. Attack-graph research has long represented multistep compromise paths and used graph analysis to reason about defensive interventions [9][10]. Identity attack-path analysis, including BloodHound-style graph reasoning, demonstrates the value of making privilege and control paths explicit [11]. Relationship-based authorization systems such as Zanzibar show a different but relevant lineage: large-scale authorization decisions can be expressed through relationships between subjects and objects [12]. Earlier trust-management work similarly formalized trusted actions, credentials and delegated policy decisions [13], while the confused-deputy problem remains a foundational warning about exercising authority on another principal's behalf [14].

Assurance-case practice is another close intellectual relative. ISO/IEC/IEEE 15026-2:2022 specifies assurance-case structure terminology for claims, arguments and evidence, reinforcing the broader lineage of evidence-linked assurance reasoning [18]. Work critiquing weighted vulnerability indices is also relevant to PEI's explicit limitations: Spring et al. argue that CVSS severity scoring should not be treated as a risk score and question the

formal and empirical justification of its scoring algorithm [19]. These precedents strengthen, rather than weaken, ATG's insistence that arithmetic remain bounded by declared semantics, evidence and decision purpose.

AI-specific work adds further adjacent concepts. Indirect prompt injection demonstrates that data can become an influence channel capable of steering an LLM-integrated application and affecting downstream tool use [15]. CycloneDX ML-BOM and the SPDX 3 AI Profile provide structured approaches to AI/ML component transparency [16][17]. The World Economic Forum's 2026 Agent Capability and Authorization Profile (ACAP) is a particularly close contemporary precedent for deployment-level authorization: it focuses on defining, enforcing and auditing what an agent is permitted to do [8]. OWASP's Agent Control Standard likewise emphasizes inspectability, traceability, middleware control hooks and runtime policy enforcement [7].

ATG does not claim that graphs, attack paths, trust relationships, authorization models, evidence-supported assurance, maturity models or delegated-authority governance are individually novel. Its proposed contribution is the governed integration of connected-system representation; conditions; trust; authority and influence; path reasoning; consequence; control breakpoints; evidence grading and sufficiency; explicit unresolved uncertainty; maturity; assessment execution; reporting; and accountable decision-making within one AI-assurance methodology.

This integration differs in scope from adjacent work. ACAP defines an authorization profile for an agent deployment; ATG composes authority and influence assertions with conditions into paths, then links those paths to controls, evidence, uncertainty and decisions. Relationship-based authorization answers whether a subject is authorized to access an object under a policy model; ATG uses authorization as one input to a broader assurance claim about system composition. Attack graphs focus primarily on compromise progression; ATG includes security paths but also governance, provider, data, authority, resilience and assurance relationships. These are methodological distinctions, not claims of superiority.

The relevant validation question is therefore whether the integrated method is coherent, reproducible, useful and sufficiently differentiated in practice. Those questions require independent review, inter-assessor testing, sensitivity analysis and field calibration. This paper does not treat architectural synthesis as empirical validation.

1.5 Assurance must remain bounded

A credible assessment has limits. Discovery may be incomplete. Provider internals may be opaque. Runtime behaviour can change. Evidence may be stale or narrow. A path may be plausible but not sufficiently evidenced. The methodology therefore rejects the idea that every assessment must end in a single definitive number.

Its governing doctrine can be summarized as: scope before collection; evidence before conclusion; conditions before path claims; tests before effectiveness; gates before averages; review before release [ATG-7]. The goal is not to manufacture certainty. It is to make the limits of certainty visible enough that decisions remain accountable.

2. Why graph reasoning

2.1 Why a directed, labelled multigraph

The canonical representation is a directed, labelled multigraph [ATG-2]. Direction matters because authority, invocation, data movement and dependency are not generally symmetric. Labels matter because a connection called "can invoke" has a different assurance meaning

from one called "trusts", "reads from", "delegates to" or "controlled by". Multiple edges between the same objects matter because two components may simultaneously have data, identity, trust and control relationships.

This representation allows the methodology to preserve context that is easily lost in an inventory or undifferentiated architecture diagram. A relationship is not merely a line. It is an assertion with scope, conditions, evidence and confidence. A path is not merely reachability in the mathematical sense. It is an ordered explanatory structure whose material steps and preconditions must be supported or explicitly marked unresolved.

2.2 The canonical reasoning chain

The Core Conceptual Model defines one reasoning chain as the intellectual spine of ATG [ATG-2 Section0.10]:

Objects -> Relationships -> Conditions -> Paths -> Authority and Influence -> Consequence -> Controls -> Evidence -> Decision

Objects establish what exists within the system boundary. Relationships establish how those objects interact. Conditions capture the permissions, protocol, state, data, approval, timing and other prerequisites that must hold. Paths combine relationships under those conditions. Authority and influence explain who or what can cause, steer or shape an outcome; for example, content can influence without possessing authority [ATG-2 Section0.10-1.1]. Consequence explains why the path matters. Controls identify where progression can be stopped, constrained, detected or contained. Evidence determines what the assessment can defend. Decision records the accountable disposition without changing the underlying assessed condition.

This chain is distinct from both the six-domain assessment model and the thirteen-phase lifecycle. It is not a maturity ladder, workflow sequence or scoring pipeline; it is the conceptual reasoning order used to explain an assurance claim.

!Figure 1. Canonical ATG reasoning chain. (figures/figure-1-canonical-reasoning-chain.png)

2.3 Graph locality, systemic consequence and missing-path risk

A graph supports movement between local detail and systemic effect. A read-only retriever may appear low risk locally, yet its output can influence an agent that can invoke a consequential tool [ATG-2]. A weak approval control may sit on many paths to high-impact actions. Conversely, a visually alarming connection may not support a material claim when necessary permissions, protocols, state or other conditions are absent.

The corresponding anti-error rule is strict: a topological connection does not prove authorization, invocation or exploitability. Required conditions must be evidenced or explicitly preserved as unresolved. PathState records the strength of support for the path rather than allowing graph density to masquerade as certainty.

The inverse error is equally important: a missing represented edge or path is not evidence that no real relationship or path exists. Discovery can be incomplete, external-provider relationships can be opaque, runtime composition can change, and graph snapshots can lag the system. ATG therefore treats discovery coverage, provenance and unresolved population as part of assurance rather than assuming that an apparently clean graph proves absence of exposure.

2.4 Boundaries are first-class

The Core Conceptual Model defines a boundary as a first-class object representing a change in trust assumption, ownership, policy, enforcement, residency, privilege or consequence [ATG-2 Section3.2]. Boundaries are therefore analytical objects rather than drawing conventions. Provider transitions, account and privilege boundaries, human-approval points, data-handling changes and responsibility transfers can all be material.

This matters in AI ecosystems because a workflow can move quickly across organizational and technical domains: a user input can influence a hosted model, that model can steer an agent, the agent can invoke a third-party tool, and the resulting action can affect an enterprise system. Making the boundary crossings explicit allows the assessor to test whether identity, authorization, evidence and control assumptions remain valid after each transition.

3. The AI Trust Graph model

3.1 Core objects and conditional relationships

The whitepaper uses a compact vocabulary while leaving the full ontology to Artifact #12. Nodes represent typed assets and assessment objects such as identities, agents, applications, tools, data resources, providers, controls, evidence objects, findings and decisions. Relationships are directional assertions. A material relationship carries endpoints, type, direction, scope, conditions, evidence, confidence, validity and review status. An edge without adequate conditions and evidence remains a candidate description rather than an approved fact [ATG-2][ATG-12].

The model therefore avoids treating an architecture line as equivalent to an assurance claim. CAN_INVOKE, TRUSTS, data movement, delegation, dependency and control coverage have different semantics even when they connect the same two objects.

3.2 Trust as conditional reliance

Trust is conditional reliance by one entity on another entity, assertion, output, dependency or control for a defined purpose [ATG-12]. A material trust relationship records purpose, basis, scope, owner, any explicit transitivity rule, expiry, revocation and evidence. Trust is non-transitive by default in the ontology: reliance through an intermediary is not silently inherited without explicit constraints.

3.3 Authority as effective or permitted capacity

Authority is the effective or permitted capacity of an actor, identity, application, agent, tool or workflow to access, influence or change a target [ATG-12]. A material authority assertion records the acting identity, capability, target, scope, conditions, duration, approval, reversibility, telemetry and revocation.

Trust and authority are distinct but interacting concepts. Trust concerns accepted reliance; authority concerns permitted or effective capacity. A trusted output need not carry authority, while an authorized component need not be trusted for every purpose. Trust relationships can nevertheless amplify effective authority or consequence when they feed downstream decision or action paths.

3.4 Reachability, PathState and PathRole

Reachability may be Direct, Indirect, Chained, Inherited, Delegated or Unknown [ATG-12]. The

reachability form Unknown is distinct from the assessment result state UNKNOWN.

A path records a start condition, ordered traversal, conditions, boundary crossings, target, controls, evidence and confidence, and any residual path. ATG separates two orthogonal dimensions that MUST NOT be collapsed [ATG-2 Section6.3]:

PathState | Meaning in the current analysis

---|---

Candidate | Hypothesized sequence requiring review

Topological | Traversal exists in the represented graph

Plausible | Required conditions are supported or explicitly UNKNOWN

Validated | Authorized testing or direct evidence confirms scoped progression

Exploitable | Evidence demonstrates a security exploit path within stated conditions

Controlled | Validated controls prevent, constrain, detect or contain the path as claimed

Invalidated | Evidence disproves a required step or condition

PathRole is separately Primary, Alternate or Residual. A residual or alternate path retains its own PathState. This separation prevents a controlled primary route from hiding another material route and prevents intervention status from being confused with evidentiary strength.

!Figure 2. Illustrative path reasoning with explicit conditions, authority and candidate control breakpoints. (figures/figure-2-path-reasoning.png)

3.5 Historical integrity

Completed assessment runs are historical records. Later evidence, architectural change or remediation does not rewrite prior conclusions. New evidence creates a new or superseding state. Version discipline supports reproducibility without pretending that an earlier assessment remains current after material change.

4. Trust, authority, influence and material paths

4.1 Trust, authority and influence must remain distinguishable

Trust, authority and influence interact but are not interchangeable. A system may trust a provider output for summarization while granting the provider no authority to modify enterprise records. Conversely, an agent may possess write authority while its generated recommendation is not trusted for autonomous approval. Influence adds a third dimension: content can steer a model or agent without possessing an identity, permission grant or trusted status.

Indirect prompt injection is a concrete example. Adversarial text embedded in retrieved content can influence an LLM-integrated application and thereby shape downstream API or tool invocation [15]. In ATG terms, the content need not hold authority itself; the risk emerges when its influence is composed with the authority of the agent, tool or workload identity. This distinction is essential to AI-native path reasoning.

4.2 Authority amplification

Canonically, authority amplification occurs when a path gives an entity greater effective power, reach, speed, scale or consequence than a local grant suggests [ATG-2 Section5.4]. Amplification is a system property and is not necessarily a single-component misconfiguration.

Artifact #2 identifies seven amplification lenses: Identity amplification, Tool amplification, Data amplification, Workflow amplification, Temporal amplification, Trust amplification, and Blast-radius amplification. These conceptual lenses should not be confused with the PEI boundary-amplification component, which is a specific scoring input defined by Artifact #4.

Delegation deserves particular scrutiny. Canonical controls retain the grantor/delegate distinction, actor-subject chain and accountability, including protection against confused-deputy behaviour. An AI agent acting through another principal's identity or authority can therefore create a materially different path from an agent that merely produces a recommendation [ATG-5][14].

4.3 Path validation

A connection in a graph is not a validated path. A path claim must preserve the conditions under which traversal is possible: identity, permissions, protocol, state, data, approval, timing and other prerequisites. The assessor records those conditions and the evidence supporting them. Unsupported material conditions remain unresolved and constrain the PathState.

This prevents two opposite errors: assuming that every visible route is exploitable, and assuming that an unobserved route does not exist. Validation strengthens a specific scoped claim; it does not prove complete discovery of the estate.

4.4 Alternate and residual paths

Interventions must be evaluated against alternate and residual routes. Appendix B.2 of Artifact #10 provides current rc.4 calibration for this rule. In P-CAL-12, a primary route is Controlled at PEI 18 (Low), while an alternate route remains PEI 38 (High). The expected result is to score the alternate path separately and not conclude that the target is controlled merely because the primary route is controlled [ATG-10 B.2].

This illustrates why PathRole and PathState remain independent: controlling one route is not evidence that equivalent routes are controlled.

5. The six assurance domains

The canonical control library contains seventy-two controls: twelve controls in each of six domains [ATG-5]. The whitepaper does not reproduce those controls; it explains how the domains divide the assurance problem.

5.1 D1 - Discovery and AIBOM

Discovery establishes the assessed estate, ownership, dependencies, source coverage and blind spots. An AI Bill of Materials (AIBOM) supports lineage across models, data, identities, tools, runtime components and dependencies. The domain does not assume that automated discovery proves completeness. Coverage and unresolved population remain visible.

5.2 D2 - Trust and Privilege Paths

This domain represents trust relationships, identity and privilege paths, boundaries, provider dependencies, path conditions and graph quality. It is where the methodology asks whether a topological route is actually supported by the permissions, state and evidence

required to make it material.

5.3 D3 - Authority Governance

Authority Governance focuses on what actors and machine entities can actually cause: action taxonomy, delegation, impersonation, least authority, approvals, amplification, resource limits, data destination authority, segregation, revocation and recertification. For agentic AI, this domain is the bridge between model behaviour and operational consequence.

5.4 D4 - AI Security Validation

Security Validation converts threat hypotheses into authorized testing. It covers model, prompt, context, retrieval, memory, agent, multi-agent, tool, MCP, supply-chain, runtime and control-breakpoint testing. Testing is governed by rules of engagement and safety; a technically possible test is not automatically authorized [ATG-7].

5.5 D5 - AI Governance and Assurance

This domain connects technical assurance to policy, risk appetite, use-case intake, impact and misuse assessment, jurisdiction and obligations, lifecycle approval, exceptions, provider due diligence, competence and independent assurance. It prevents technical controls from becoming disconnected from decision rights and business accountability.

5.6 D6 - Operational Resilience

Operational Resilience covers telemetry, attribution, detection, incident taxonomy, triage, containment, agent kill or pause mechanisms, credential and delegation revocation, rollback, business recovery, evidence preservation and exercises. It asks not only whether a path can be prevented, but whether the organization can detect, contain and recover when prevention fails.

5.7 The domains are integrated, not six silos

A material issue often crosses domains. A broad service identity may originate as a D3 authority problem, create a D2 privilege path, require D4 validation, depend on D1 inventory accuracy, trigger D5 exception governance and require D6 containment capability. The six-domain profile is therefore intended to show uneven capability without collapsing it into one number.

6. Control breakpoints

6.1 Controls as graph interventions

A control breakpoint is a node, relationship or boundary where an effective control can materially stop, constrain, detect or contain a path [ATG-2][ATG-12]. Breakpoint analysis asks where an intervention produces the greatest defensible reduction in material exposure while considering ownership, feasibility, independence, user impact, resilience and alternate routes.

Recovery, rollback, compensation, incident reconstruction and forensics remain important controls and resilience outcomes, particularly in D6, but they are related to rather than part of the canonical breakpoint definition. Keeping that boundary clear prevents post-event recovery capability from being described as if it had interrupted the causal path itself.

6.2 Design intent is not operating effectiveness

ATG distinguishes control design, implementation and operating effectiveness. A documented approval requirement can support design evidence, but it does not prove that the production workflow enforces the approval every time. A configuration export may demonstrate implementation, but an operating-effectiveness claim requires stronger evidence from current representative operation under the relevant conditions [ATG-6].

This distinction is essential for breakpoint reasoning because a path is only constrained to the extent that the breakpoint actually operates. A control drawn on an architecture diagram is not automatically a path cut.

6.3 Independence and concentration

Breakpoints should also be reviewed for independence. Two nominally separate controls may depend on the same identity provider, administrator or policy engine. If that common dependency fails, the graph can reveal correlated control failure. Conversely, a strategically placed independent breakpoint can reduce multiple material paths.

The purpose is not to optimize purely for the largest number of graph edges removed. Remediation must still consider consequence, feasibility, ownership, resilience and the risk of creating alternate routes.

7. Evidence and epistemic discipline

7.1 Evidence is a relationship, not a document count

The canonical Evidence Model states that evidence is a governed relationship between a source and a precisely stated assertion within defined scope, time, conditions and limitations [ATG-6]. This is a fundamental design choice. An assessment should be able to explain what was observed, how it was obtained, what the evidence supports, what it does not support, and who approved the conclusion.

The model separates evidence grade, evidence quality, assertion confidence, coverage and reviewer decision. Combining these dimensions into one score would create false certainty.

7.2 Evidence grades E0-E5

Evidence grade describes support for an assertion; it does not describe whether the observed state is desirable, safe, compliant or effective. E0, No evidence: no source is available or the supplied item cannot be linked to the assertion [ATG-6 Section1.1]. The only defensible conclusion in that circumstance is UNKNOWN or Not Tested, as applicable; E0 is not evidence that a control is absent.

A separate scoring rule is equally important: absence of a linked EvidenceItem is not itself an E0 EvidenceItem. E0 is used only where an E0 evidence basis is explicitly recorded and reviewed under the Evidence Model [ATG-4 Section1.8].

At the other end of the scale, E5 represents direct current technical evidence plus representative test or operating record within stated scope. Even E5 does not equal truth or a favourable result. A high grade can confirm an adverse state, while a low grade can weakly suggest a favourable state [ATG-6 Section1.8].

!Figure 3. Evidence support and control effectiveness are distinct dimensions.

(figures/figure-5-evidence-effectiveness.png)

7.3 Sufficiency is claim-specific

Evidence sufficient for one component claim does not support another. Sufficiency is decided separately for design, implementation, operating effectiveness and, where a level-5 (component score of 5) or adaptive claim is made, level-5 and adaptive operation [ATG-6 Section4.1]. A finalized numeric component score requires an approved Evidence Sufficiency Decision and an approved reviewer decision.

The canonical minimums are claim-specific: design requires E3 or stronger; implementation, for any score 0-5, requires E4-or-stronger technical evidence from the deployed or configured environment; operating effectiveness requires E5-quality evidence; and a score of 5 or adaptive/continuous-assurance claim requires repeated E5-quality evidence across relevant material changes. Meeting the grade threshold is necessary but not sufficient: relevance, scope, currentness, representativeness and conflict status still govern.

7.4 Evidence-supported score caps

For a control component claim, the evidence cap is the approved evidence-support ceiling. It limits the highest component score the evidence can support; it is not an entitlement and it does not convert evidence quality into effectiveness [ATG-4 Section1.8]. The rule applies equally to favourable and adverse observations.

Current rc.4 calibration makes the distinction concrete. In S-CAL-05, E3 policy/procedure evidence supports design but cannot finalize implementation; the overall remains unset and the conclusion is UNKNOWN with an Evidence Gap. In S-CAL-07c, an E5 runtime bypass test is materially relied upon for an adverse operating-effectiveness claim; the supported operating-effectiveness score is 1, the overall is 1, and the result is a Control Deficiency with Medium confidence [ATG-10 B.5]. Strong evidence can therefore confirm that a control performs poorly without being transformed into a high effectiveness score.

7.5 Conflict and provenance

Evidence can support, dispute, qualify, corroborate, derive from, supersede or duplicate another assertion or evidence item. Conflicting evidence remains visible until it is resolved or the conclusion is bounded. Provenance and supersession are retained so that the assessment can be reconstructed later.

This discipline is also the boundary for AI-assisted analysis. AI-generated extraction, classification or summarization may propose assertions, but model output cannot silently become approved fact. Material facts, risk acceptance and high-impact decisions require accountable human approval [ATG-1].

8. UNKNOWN and bounded assurance

8.1 UNKNOWN is a first-class state

The canonical assessment-state definition is precise: UNKNOWN means evidence is absent, insufficient or materially conflicting [ATG-6][ATG-12]. UNKNOWN is not zero, safe, failed, passed, effective, low risk, Not Applicable or Not Tested. It remains visible until sufficient evidence and accountable review resolve the material assertion.

UNKNOWN is also distinct from Inconclusive. UNKNOWN applies when the material state remains

unresolved because evidence is absent, insufficient or materially conflicting. Inconclusive applies when authorized testing, review or resolution activity occurred but the evidence still cannot support a determinate conclusion [ATG-6 Section0.5]. These states must not be collapsed for dashboard convenience.

The reachability form Unknown uses title case and answers a different question: a potentially material route lacks sufficient evidence. It must not be confused with the all-caps assessment result state UNKNOWN.

8.2 Why UNKNOWN matters for paths

Path analysis must not manufacture a number from unresolved material conditions. If an UNKNOWN condition affects any numeric PEI component, a final point PEI is not published. The assessor retains the affected component as UNKNOWN and may show an explicit bounded provisional range only when decision-useful [ATG-4 SectionSection4.2, 4.8]. If a required reachability condition is disproved, the PathState becomes Invalidated and there is no active PEI.

Artifact #10 provides an rc.4 calibration vector for exactly this case. P-CAL-09 has Consequence 4, Reachability UNKNOWN, Authority 3, Amplification 2 and Control Resistance 2. The expected result is no final point PEI; if useful, the provisional range for R=1..4 is 38-47. P-CAL-10 then shows the opposite resolution: when the required reachability condition is disproved, the path becomes Invalidated and retains no active PEI [ATG-10 B.1].

8.3 Bounded assurance

This leads to a broader doctrine: assurance should be no stronger than the evidence and declared scope permit. The methodology therefore prefers a narrower, defensible statement over a broad but weak one. "Final within scope" is not the same as universal truth; it means required review and evidence gates are complete for the declared scope.

Bounded assurance is not a weakness in the methodology. It is a control against false precision. In complex AI ecosystems, the ability to state what remains unknown can be as decision-relevant as the ability to state what has been verified.

9. Assessment lifecycle

Artifact #7 defines thirteen canonical phases. The whitepaper preserves their names and order and summarizes the expected output without redefining the method:

Phase | Primary outcome [ATG-7]

---|---

1. Initiate | Approved charter and decision purpose.
2. Scope | Versioned boundary and population.
3. Discover | Measured estate and blind spots.
4. Model | Reviewed graph snapshot.
5. Evidence | Graded and traceable evidence set.
6. Controls | Applicability and control results.
7. Paths | Validated material path portfolio.
8. Maturity | Six-domain capability profile.
9. Scoring | Transparent scorecards and coverage.
10. Findings | Evidence-linked gaps and remediation objectives.
11. Decisions | Approved gates, exceptions and dispositions.
12. Report | Quality-reviewed decision package.

13. Reassess | Trigger-based new or updated run.

The lifecycle is gate-driven. The thirteen canonical phase gates are: Initiation gate, Scope baseline gate, Discovery gate, Graph approval gate, Evidence sufficiency gate, Control determination gate, Path conclusion gate, Maturity approval gate, Scoring quality gate, Finding release gate, Decision gate, Report release gate, and Closure and continuity gate [ATG-7 Section2.4-14.4]. Operational entry and exit criteria remain in Artifact #7.

!Figure 4. Thirteen-phase assessment lifecycle and gates.
(figures/figure-3-lifecycle-gates.png)

The lifecycle should not be read as a one-time waterfall. A new provider, permission, model version, tool, data source, control change or material incident can trigger reassessment. Historical runs remain immutable; reassessment creates a new governed state rather than rewriting the old one.

10. Scoring and decision discipline

10.1 No overall trust score

ATG intentionally does not publish a single overall AI Trust Graph score in v1.0. The current evidence base does not justify reducing trust, authority, security, governance, resilience, uncertainty and maturity into one universal number [ATG-4 Section5.8]. A future composite may be proposed only after field calibration, sensitivity analysis, independent review, misuse analysis and public formula governance.

10.2 Maturity is cumulative and non-compensating

M1-M5 maturity is cumulative, evidence-gated and non-compensating. A higher-level feature does not compensate for a missing lower-level foundation [ATG-3 Section1.6]. At domain level, the result is the highest common level sustained by all applicable mandatory capabilities after gate review; arithmetic averages do not replace that rule [ATG-3 Section8.2].

The rc.4 calibration pair M-CAL-02 illustrates the point. D3.1 and D3.2 can be at M5 while D3.3 and D3.6 remain at M2; the domain result is M2 because advanced automation cannot compensate for the common M2 floor [ATG-10 B.3]. The preferred executive result is a six-domain vector. An overall label, if a sponsor explicitly requires one, is the minimum applicable domain level and must be accompanied by the full profile, confidence and critical gates [ATG-3 Section8.3].

10.3 Control scoring remains evidence-bounded

Control scoring separates design, implementation and operating effectiveness and remains subject to evidence sufficiency, critical gates and compatibility rules. Numerical treatment must never convert missing support into a favourable default. An observed component state may remain visible even when the supported score is lower or absent.

10.4 Path Exposure Index

For triage only, PEI may be calculated from Consequence, Reachability, Authority, Amplification and Control Resistance:

$$PEI = 4 \times \text{Consequence} + 3 \times \text{Reachability} + 3 \times \text{Authority} + 2 \times \text{Amplification} + 3 \times \text{Control}$$

Resistance

The range is 7 to 62 for determinate eligible active paths [ATG-4 Section4.9]. The primary output is an ordinal exposure band; the component profile remains the authoritative explanation. PEI does not prove exploitability, probability or loss and is not an overall trust, certification or compliance score.

Eligibility requires a defined start condition, target, traversals, material conditions and evidence state. A Plausible path receives an exposure band only when all numeric PEI components are determinate. If an UNKNOWN affects a numeric component, no final point PEI is published; a provisional component profile or bounded range may be retained. An Invalidated path has no active PEI [ATG-4 SectionSection4.2, 4.8].

Critical overrides take precedence over the arithmetic and may raise the minimum triage band where canonical override conditions apply [ATG-4 Section4.10]. The arithmetic therefore never outranks the path state, critical gate or component explanation.

Before public use of weighted or path formulas, Artifact #4 requires sensitivity analysis of reasonable changes in component ratings, weights and thresholds [ATG-4 Section6.5]. At the frozen baseline used by this whitepaper, completion of that sensitivity-analysis requirement is not recorded in the manifest as a completed release gate. This paper therefore presents PEI as canonical methodology content, not as a validated predictive instrument.

10.5 Decision discipline

A score is an input to judgment, not a substitute for it. A decision should preserve traceability from scope and claim through evidence, graph context, control or path state, finding and accountable disposition. Management acceptance changes disposition, not the underlying technical result.

11. Worked example: knowledge-copilot reasoning under rc.4

This section uses the historical RA-01 Enterprise Knowledge Copilot only as a synthetic architecture and decision-question context. Artifact #10 explicitly states that RA-01 to RA-12 are historical calibration snapshots authored under bundle 1.0-rc.3 or earlier. Their legacy control scores, evidence grades, confidence, findings, decisions and result states MUST NOT be presented as results under bundle 1.0-rc.4 or later [ATG-10 Section0.16]. Accordingly, this paper does not carry forward RA-01's legacy control scores, maturity vector or point PEI as current rc.4 results.

11.1 Historical scenario retained only for context

RA-01 describes an advisory enterprise knowledge copilot grounded in enterprise repositories and user identity. Its historical path hypothesis is:

User identity -> copilot -> retriever -> inherited broad source entitlement -> restricted document

The architectural concern remains useful for teaching: a user may lack direct entitlement to a restricted document while a retrieval component operates with a broader source entitlement. The question is not merely whether a connection exists, but which conditions govern authorization, whether influence can steer retrieval, what authority is exercised, and what evidence supports each step.

11.2 Re-execution under rc.4 starts from conditions, not legacy scores

A current rc.4 re-execution would create new component observations and approved component-specific Evidence Sufficiency Decisions. It would not reverse-engineer the historical RA-01 score into design, implementation or operating-effectiveness components. The graph would record PathState and PathRole, preserve unresolved conditions, and evaluate the current evidence rather than inheriting historical confidence.

Artifact #10 asks: Which conclusion changes if the weakest evidence item is removed, narrowed or contradicted? [ATG-10 Section1.10]. The answer depends on which claim that item supports.

11.3 Calibration lens: unresolved reachability

P-CAL-09 provides the canonical rc.4 treatment for a path whose reachability component is UNKNOWN. With C=4, R=UNKNOWN, A=3, Am=2 and CR=2, no final point PEI is permitted. If decision-useful, an explicit provisional range of 38-47 may be shown. UNKNOWN is not encoded as zero [ATG-10 B.1].

Applied as a teaching lens to the knowledge-copilot architecture, a missing representative authorization test could therefore constrain the reachability claim rather than being converted into an apparently precise PEI.

11.4 Calibration lens: disproved and alternate routes

P-CAL-10 shows the resolution case: if a required reachability condition is disproved, the PathState becomes Invalidated and there is no active PEI. P-CAL-12 then shows why one successful control does not close the analysis: a Controlled primary route at PEI 18 (Low) coexists with an alternate route at PEI 38 (High), which must be scored separately [ATG-10 B.1-B.2].

For a retrieval system, this means validating one authorization path does not establish that every provider, cache, index, tool or alternate source path enforces the same boundary.

11.5 Calibration lens: evidence sufficiency can support adverse conclusions

S-CAL-05 demonstrates an evidence gap. E3 design documentation is sufficient for a design claim but E3-only implementation evidence cannot finalize implementation; the control conclusion remains UNKNOWN and the finding is an Evidence Gap [ATG-10 B.5].

S-CAL-07c demonstrates the converse. An E5 representative bypass test is relied upon for an adverse operating-effectiveness claim. The supported operating-effectiveness score is 1, the overall supported result is 1, and the finding is a Control Deficiency with Medium confidence. High-grade evidence therefore confirms the adverse state rather than inflating the effectiveness score.

11.6 Calibration lens: maturity cannot average away weak foundations

M-CAL-02 provides the current non-compensation example. Several Authority Governance capabilities are at M4/M5, while approval/oversight and decision-governance capabilities remain at M2. The domain result is M2. Advanced automation and telemetry do not compensate for weak lower-level foundations [ATG-10 B.3].

11.7 Bounded decision logic

The worked example deliberately stops short of inventing a new rc.4 decision for RA-01. A real re-execution would require current evidence, graph state, control conclusions, gates and accountable review. The teaching outcome is instead methodological: unresolved material conditions remain visible; alternate routes remain independent; adverse evidence can support an adverse control conclusion; and advanced capability does not erase foundational gaps.

!Figure 5. rc.4 worked-example reasoning: historical scenario context with current calibration lenses. (figures/figure-4-rc4-worked-example.png)

12. Reporting and accountable decisions

12.1 The graph is not the final deliverable

The purpose of an assessment is not to produce an impressive network visualization. The graph is an analytical substrate. The report must translate graph context into claims, evidence, findings and decisions without hiding scope or uncertainty.

The canonical Reporting Standard requires, among other elements, document control and assessment identity, an executive conclusion and purpose, versioned scope, method and limitations, estate and AIBOM view, trust and boundary view, authority view, control assessment, path portfolio, maturity profile, scorecards and coverage, findings, decisions, roadmap, limitations and sign-off [ATG-9 Section1]. Executive reporting must disclose critical gates, coverage and residual uncertainty rather than reduce the result to a traffic light.

12.2 Findings remain separate from disposition

A finding records the technical or assurance condition. Management acceptance, exception or treatment records what the organization decides to do about it. Acceptance does not make the underlying condition disappear. This separation preserves technical integrity and allows future reviewers to understand whether risk changed or only its disposition changed.

12.3 Traceability survives to the decision

A defensible decision should be traceable back to the evidence and graph context that support it. This is particularly important for consequential AI because policy statements and high-level risk language can otherwise become disconnected from the actual system path. ATG's reporting discipline is intended to preserve the chain from observed state to accountable action.

13. Limitations and current validation status

13.1 Methodological coherence is not empirical validation

A governed methodology can be internally coherent without having demonstrated that independent assessors will apply it consistently across real organizations. The current artifact stack includes synthetic calibration material and a reproducibility protocol, but the frozen baseline explicitly records inter-assessor reproducibility validation as a pending external gate.

13.2 Synthetic cases are not field proof

Artifact #10 contains synthetic reference cases designed for calibration, adversarial checks

and reasoning consistency. They must not be represented as observed facts about real vendors or organizations. A synthetic worked example can demonstrate how rules interact; it cannot prove predictive validity, business impact or external effectiveness.

13.3 Scoring has known limits

The Scoring Framework states that ordinal judgments do not become objective probabilities merely because arithmetic is applied. PEI weights and thresholds require calibration, and Artifact #4 requires sensitivity analysis before public use of weighted or path formulas. At the frozen baseline, this paper does not claim that field calibration, inter-assessor calibration or the required sensitivity analysis has established predictive validity or stable cross-organization rankings.

13.4 Evidence and discovery have limits

The Evidence Model cannot guarantee source truth, complete discovery, legal admissibility, statistical representativeness, absence of deception or permanent currency [ATG-6]. A graph can also under-represent reality: shadow AI, undocumented identities, provider internals, runtime-created tool paths or stale discovery data can leave material relationships absent from the represented graph. Not finding a path is therefore not evidence that no path exists.

13.5 Dynamic and stochastic systems create additional limitations

Agentic systems can compose tool paths at runtime, registries and tool descriptions can change, providers can update models without synchronizing an assessment, and long-running agents can accumulate state across interactions. A versioned graph snapshot can bound what was represented and assessed at a point in time; it cannot guarantee that every future runtime composition is already enumerated.

Some AI controls are probabilistic rather than deterministic. Classifiers, content filters and LLM-based guardrails can have measured error rates and correlated failure modes. The current canonical methodology does not define a special mapping from probabilistic control performance to Validated block, Control Resistance or E5. This paper therefore identifies stochastic-control treatment as an open methodology question rather than inventing a scoring rule.

Large estates also create path-explosion and selection-bias risks. Assessor decisions about which paths are material enough for deeper validation can shape the resulting portfolio. Coverage, selection criteria and unresolved populations should therefore remain visible.

13.6 No guarantee of safety, compliance or certification

AI Trust Graph assessments do not guarantee future system behaviour, complete risk elimination, legal compliance or absence of failure. The governance model prohibits scores, maturity levels, conformance statements, marks, badges or future certificates from implying guaranteed safety, trustworthiness, compliance or absence of failure [ATG-11]. Version 1.0 defines certification-readiness architecture; it does not launch an accredited certification scheme.

13.7 Frozen validation and release status for this paper

As of methodology bundle 1.0-rc.4, the manifest Section6 external release gates remain: independent methodology or architecture review; independent AI-security review;

inter-assessor reproducibility study; employer/IP/confidentiality review; and legal approval of the licence/trademark position. These are not the only open readiness items across the artifact stack; specialist artifacts also contain their own validation and acceptance requirements. If the status changes later, this historical paper should remain unchanged and a new version should update the record.

The methodology author's internal review should be understood as author-led/internal methodology review, not independent validation.

13.8 Validation agenda

The next credibility step is empirical rather than rhetorical. Without changing canonical semantics, independent evaluation should test whether separate assessors reach materially consistent conclusions from the same evidence; whether path and breakpoint reasoning remains stable under realistic architectural change; whether discovery coverage and path selection remain defensible in large estates; whether PEI weights and bands remain useful under the required sensitivity analysis and field calibration; and whether resulting reports improve decision traceability without encouraging false precision [ATG-4][ATG-10].

This agenda is non-normative except where an item is already required by the canonical artifacts. In particular, sensitivity analysis before public use of weighted/path formulas is a canonical Scoring Framework requirement, not merely a future research preference.

14. Governance and methodology evolution

14.1 Scope-based authority

The methodology does not use a simplistic one-dimensional precedence order. The Methodology Manifest resolves authority by scope: the Manifesto governs public purpose and non-negotiable commitments; the Core Conceptual Model governs conceptual semantics; the Ontology formalizes those semantics; specialist artifacts govern maturity, scoring, controls, evidence, execution, reporting and governance within their declared authority [ATG-M].

If a conflict is detected, the affected conclusion or claim is paused, evidence and version state are preserved, and the issue is resolved through governance. The whitepaper has no authority to resolve such a conflict by reinterpretation.

14.2 Controlled evolution

Canonical concepts, control IDs, evidence grades, maturity semantics and scoring logic change only through governed methodology change. Published versions and completed assessments remain immutable historical records and are superseded rather than overwritten. This principle protects the methodology from silent semantic drift and allows users to reconstruct which rules were applied to a particular assessment.

14.3 Tool independence

The methodology can be executed with documents, spreadsheets, graph stores or compatible platforms. Tool output remains proposed until evidence, scope, method and review support acceptance. A commercial implementation may automate execution but cannot become a hidden source of canonical meaning.

Artifacts #8 and #10 provide assessor guidance and reference calibration respectively and

cannot override the normative artifacts within their declared authority. Artifact #13, the Reference Graph Schema and Illustrative Query Library, is a Phase 2 non-normative companion. It carries no conformance weight at this baseline and cannot redefine the twelve core artifacts. L4 Tool-compatible conformance is explicitly unavailable until approved normative machine-readable schemas and conformance test vectors exist [ATG-M].

14.4 Publication boundary

This whitepaper is intentionally a front door. It synthesizes the reasoning model but does not replicate the seventy-two controls, complete M1-M5 capability matrices, full E0-E5 tables, ontology registry, scoring tables, assessor field guidance, reporting templates or implementation query library. Readers who need operational rules should use the pinned canonical artifact stack.

Conclusion

AI assurance becomes harder when the relevant unit is no longer an isolated model but a connected system of identities, agents, tools, data, providers, workflows and human decisions. In such systems, consequential exposure can emerge through composition: conditions enable paths; authority or influence shapes what can happen; controls interrupt some routes but not necessarily alternates; and evidence determines how strongly any conclusion can be defended.

AI Trust Graph proposes a governed way to reason through that composition using its canonical chain: Objects -> Relationships -> Conditions -> Paths -> Authority and Influence -> Consequence -> Controls -> Evidence -> Decision. It separates trust from authority while modelling their interaction, preserves PathState and PathRole, distinguishes evidence support from effectiveness, keeps UNKNOWN visible, and uses maturity and PEI only within bounded purposes.

The methodology remains a public-release candidate at the frozen baseline. Historical calibration is not current field validation, synthetic vectors are not empirical risk observations, and several release and methodology questions remain open. Its credibility will therefore depend on independent challenge, reproducibility, sensitivity analysis, field calibration, transparent governance and disciplined refusal to turn uncertainty into a convenient number.

Better assurance does not require pretending that every uncertainty can be scored away. It requires knowing what can be concluded, why it can be concluded, which conditions and paths the conclusion depends on, and where the evidence requires the answer to remain UNKNOWN.

Appendix A. Whitepaper-to-canonical traceability matrix

Whitepaper subject	Canonical authority	Semantic guardrail
Publication status / authority | METHODOLOGY_MANIFEST.md; #1; #11 | Non-normative paper; canonical artifacts prevail; frozen validation status
Assurance problem | #1; #2 | System-level reasoning; composition and path emphasis; complement existing standards
Graph reasoning | #2; #12 | Canonical nine-step chain; directed labelled multigraph; conditional relationships; topology is not exploitability
Trust | #2; #12 | Conditional reliance; purpose/basis/scope/owner/revocation/evidence; non-transitive by default
Authority | #2; #12 | Effective/permitted capacity;

identity/capability/target/scope/conditions/approval/revocation

Paths | #2; #4; #6; #12 | Conditions; PathState and PathRole; UNKNOWN numeric components
block final point PEI; residual and alternate paths

Six domains | #3; #5 | Exact canonical domain names; 12 controls per domain; do not
reproduce full catalog

Control breakpoints | #2; #5; #12 | Stop/constrain/detect/contain; design is not operating
effectiveness

Evidence | #6; #4 | E0-E5; grade is support not truth; sufficiency is claim-specific;
evidence cap is a ceiling not an entitlement

UNKNOWN | #4; #6; #7; #9; #11; #12 | Evidence absent/insufficient/materially conflicting;
never zero/pass/fail/effective/NA; distinct from Not Tested and Inconclusive

Lifecycle | #7 | Exact 13 phases: Initiate, Scope, Discover, Model, Evidence, Controls,
Paths, Maturity, Scoring, Findings, Decisions, Report, Reassess

Maturity | #3 | M1-M5 cumulative, evidence-gated and non-compensating; no averaging
PEI | #4 | Exact formula and 7-62 eligible determinate range; triage only; does not prove
exploitability, probability or expected loss

Worked example | #10 | RA-01 architecture only as historical context; rc.4 mechanics use
Appendix B current calibration vectors; no legacy score carry-forward

Reporting | #9 | No one-number trust score; disclose coverage, uncertainty, critical gates
and evidence

Governance | #11; Manifest | Scope-based authority; historical integrity; tool
independence; #13 non-normative

ExposureGraph boundary | #1; #2; #7; #11 | Product and proprietary implementation excluded

References

- [1] Tabassi, E. (2023). Artificial Intelligence Risk Management Framework (AI RMF 1.0). NIST AI 100-1. DOI: 10.6028/NIST.AI.100-1.
- [2] Autio, C., Schwartz, R., Dunietz, J., Jain, S., Stanley, M., Tabassi, E., Hall, P., & Roberts, K. (2024). Artificial Intelligence Risk Management Framework: Generative Artificial Intelligence Profile. NIST AI 600-1. DOI: 10.6028/NIST.AI.600-1.
- [3] ISO/IEC 42001:2023. Information technology - Artificial intelligence - Management system. International Organization for Standardization.
- [4] ISO/IEC 23894:2023. Information technology - Artificial intelligence - Guidance on risk management. International Organization for Standardization.
- [5] MITRE ATLAS. Adversarial Threat Landscape for AI Systems. <https://atlas.mitre.org/>
- [6] OWASP GenAI Security Project. (2025). OWASP Top 10 for Agentic Applications for 2026. Released 9 December 2025. <https://genai.owasp.org/resource/owasp-top-10-for-agentic-applications-for-2026/>
- [7] OWASP GenAI Security Project. (2026). Agent Control Standard (ACS). Resource dated 1 September 2026. <https://genai.owasp.org/resource/agent-control-standard-acs/>
- [8] World Economic Forum. (2026). AI Agents in Action: A Playbook for Trusted Adoption, Authorization and Scaling. 26 May 2026.
- [9] Swiler, L. P., Phillips, C., Ellis, D., & Chakerian, S. (1998). A graph-based network-vulnerability analysis system. Sandia National Laboratories. DOI: 10.2172/573291.
- [10] Sheyner, O., Haines, J. W., Jha, S., Lippmann, R., & Wing, J. M. (2002). Automated Generation and Analysis of Attack Graphs. Proceedings of the IEEE Symposium on Security and Privacy, pp. 273-284. DOI: 10.1109/SECPRI.2002.1004377.
- [11] SpecterOps. (2017). BloodHound 1.3 - The ACL Attack Path Update. <https://specterops.io/blog/2017/05/15/bloodhound-1-3-the-acl-attack-path-update/>
- [12] Pang, R., Caceres, R., Burrows, M., Chen, Z., Dave, P., Germer, N., Golynski, A., Graney, K., Kang, N., Kissner, L., Korn, J. L., Parmar, A., Richards, C. D., & Wang, M. (2019). Zanzibar: Google's Consistent, Global Authorization System. USENIX ATC 2019, 33-46.
- [13] Blaze, M., Feigenbaum, J., & Lacy, J. (1996). Decentralized Trust Management. IEEE

Symposium on Security and Privacy, 164-173. DOI: 10.1109/SECPRI.1996.502679.

[14] Hardy, N. (1988). The Confused Deputy (or why capabilities might have been invented). ACM SIGOPS Operating Systems Review, 22(4), 36-38. DOI: 10.1145/54289.871709.

[15] Greshake, K., Abdelnabi, S., Mishra, S., Endres, C., Holz, T., & Fritz, M. (2023). Not what you've signed up for: Compromising Real-World LLM-Integrated Applications with Indirect Prompt Injection. arXiv:2302.12173.

[16] CycloneDX. Machine Learning Bill of Materials (ML-BOM).
<https://cyclonedx.org/capabilities/mlbom/>

[17] SPDX. SPDX Specification 3.0.1 - AI Profile.
<https://spdx.github.io/spdx-spec/latest/model/AI/AI/>

[18] ISO/IEC/IEEE 15026-2:2022. Systems and software engineering - Systems and software assurance - Part 2: Assurance case. International Organization for Standardization.

[19] Spring, J. M., Hatleback, E., Householder, A., Manion, A., & Shick, D. (2021). Time to Change the CVSS? IEEE Security & Privacy, 19(2), 74-78. DOI: 10.1109/MSEC.2020.3044475.

[ATG-M] AI Trust Graph Methodology Manifest, bundle 1.0-rc.4, snapshot 2026-09-26, manifest blob 82c401ad27d31ddc0078e58dd99f38ac0b71a7d9.

[ATG-1] AI Trust Graph Artifact #1 - Manifesto, v1.0.

[ATG-2] AI Trust Graph Artifact #2 - Core Conceptual Model, v3.0.0.

[ATG-3] AI Trust Graph Artifact #3 - Maturity Model, v1.0.

[ATG-4] AI Trust Graph Artifact #4 - Scoring Framework, v3.0.0.

[ATG-5] AI Trust Graph Artifact #5 - Master Control Library, v2.0.0.

[ATG-6] AI Trust Graph Artifact #6 - Evidence Model, v2.0.0.

[ATG-7] AI Trust Graph Artifact #7 - Assessment Methodology, v1.1.0.

[ATG-8] AI Trust Graph Artifact #8 - Assessor Handbook, v1.0.

[ATG-9] AI Trust Graph Artifact #9 - Reporting Standard, v1.1.0.

[ATG-10] AI Trust Graph Artifact #10 - Reference Assessment Repository, v2.0.0.

[ATG-11] AI Trust Graph Artifact #11 - Governance & Certification Model, v1.0.

[ATG-12] AI Trust Graph Artifact #12 - Ontology Specification, v3.0.0.

[ATG-13] AI Trust Graph Artifact #13 - Reference Graph Schema and Illustrative Query Library, v0.4.0, Phase 2 non-normative companion.